



SOLICITUD DE VALIDACION

Validacion de DevOps e Infraestructura antes de salir a produccion

Ecosistema Hacienda Nayarit · NAY-ING-STE · Hito de remediacion de calidad y seguridad

Hito en Zoho	projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037479054
Que se pide	Validar 4 temas en pruebas internas y valorar 4 sin iniciar
Base del analisis	14 subtareass, 64 comentarios y 11 PRs
Fuentes tecnicas	SonarQube, pentest y Lighthouse (2026-07)
Fecha	2026-09-08

DIRIGIDO A DEVOPS E INFRAESTRUCTURA

Por que les llega esto

El hito de remediacion tiene 14 subtareass. Al revisar los comentarios de cada una aparecen **cuatro temas que dependen de infraestructura y que hoy nadie ha cerrado**, mas cuatro que estan sin iniciar y necesitan su valoracion. Dos de ellos ya fueron consultados a infra en Zoho y quedaron sin respuesta definitiva.

Lo que necesitamos de ustedes

#	Peticion	Estado hoy	Riesgo si no se valida
1	Confirmar el comportamiento de HTTPS en productivo con el balanceador Huawei. Infra ya dijo en Zoho que no esta 100% seguro	Pruebas internas	Sitio caido
2	Definir donde se emiten las cabeceras de seguridad (nginx o Django) y con que valores. Hoy solo consta una de cinco	Pruebas internas	Cobro caido
3	Validar el rate limiting del webhook de NetPay: quedo en 10 peticiones por minuto por IP	Pruebas internas	Pagos sin conciliar
4	Revisar la configuracion de nginx del iframe de la pasarela. Ya provoco una falla el 25 de agosto	Listo para QA	Cobro caido
5	Tomar la restriccion de CORS. Ya esta asignada a Miguel Angel Ramos desde el 21 de julio, sin arrancar	No iniciada	Fuga de datos
6	Retomar el bloqueo del reporteador ASP.NET. Se cancelo por ser tema de firewall, no porque se resolviera	Cancelada	App interna expuesta
7	Definir quien ejecuta la rotacion de las llaves NetPay de produccion. Sin un solo comentario en Zoho	No iniciada	Riesgo financiero
8	Valorar las palancas de infraestructura para el rendimiento del portal publico: compresion, cache, CDN e imagenes	No iniciada	Experiencia

El punto mas urgente. El 14 de agosto Arlethe Mora pregunto en Zoho si el cambio de nginx era correcto. Miguel Angel Ramos respondio:

"en el servidor de pruebas el cambio deberia funcionar correctamente, ya que el balanceo lo realiza Nginx y tenemos control de que el acceso se maneja mediante HTTPS. En productivo, en teoria tambien deberia funcionar, ya que el balanceador de Huawei es el que gestiona el certificado y la conexion externa es HTTPS. Sin embargo, en ese punto no estoy 100 % seguro"

Esa duda sigue abierta desde entonces y la subtaska sigue en pruebas internas. Es exactamente el escenario que puede dejar el sitio inaccesible.

Lo que esta en pruebas internas: que se hizo y que falta

Reconstruido a partir de los comentarios de cada subtarea. Lo marcado como pendiente es lo que **no consta** en Zoho: puede estar hecho y sin registrar, y por eso hace falta confirmarlo.

1 · Forzar HTTPS en redirects y paginacion DRF

projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037475081

QUE SE HIZO (SEGUN COMENTARIOS)

- Se configuro `USE_X_FORWARDED_HOST = True` en `production.py` y `development.py` para que la paginacion DRF genere URLs https. Arlethe Mora, 27-jul.
- Se ajusto la configuracion para que el servidor mande https y agregue `/api` en la URL. PR github.com/sigob-open-source/nay_opensir/pull/116, 13-ago.
- Se modifiko un archivo de configuracion de **nginx**. PR github.com/sigob-open-source/nay_opensir/pull/101.

QUE FALTA O NO CONSTA

- **La validacion en productivo.** Arlethe lo dijo desde el 27-jul: *"Esta es la prueba en local pero se necesitaria confirmar en el servidor"*. Infra respondio que en productivo no esta seguro por el balanceador Huawei.
- **No consta que se haya activado `SECURE_SSL_REDIRECT`**, que es lo que pide textualmente el criterio de aceptacion. Lo que aparece en comentarios es `USE_X_FORWARDED_HOST`, que resuelve la generacion de URLs pero no fuerza la redireccion.

QUE PUEDE FALLAR

- **Bucle de redireccion infinito** si el balanceador Huawei no envia `X-Forwarded-Proto` como Django espera: el usuario recibe `ERR_TOO_MANY_REDIRECTS` y **cae el sitio completo**.
- Health checks internos por HTTP recibiendo redirect: el orquestador marca el servicio caido y lo recicla.

QUIEN VALIDA

Ejecuto	Arlethe Mora
Revision de codigo	Paolo Payan
Infraestructura	Miguel Angel Ramos. Confirmar que el balanceador Huawei envia <code>X-Forwarded-Proto</code> y que <code>SECURE_PROXY_SSL_HEADER</code> coincide. Es la duda que quedo abierta el 14-ago
Aprueba	Dulce Gonzalez

2 · Cabeceras de seguridad HTTP en todos los backends

projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037480070

QUE SE HIZO (SEGUN COMENTARIOS)

- Se agrego `SECURE_REFERRER_POLICY = 'strict-origin-when-cross-origin'`, verificado con Postman. Arlethe Mora, 27-jul.

El criterio de aceptacion pide cinco cabeceras y en los comentarios solo consta una. Faltan por confirmar **CSP, HSTS, X-Frame-Options y X-Content-Type-Options**, es decir las dos de mayor impacto (CSP y HSTS) y las dos de clickjacking y sniffing. La subarea esta en pruebas internas desde el 11-ago y es el hallazgo **P090, clasificado como CRITICO** en el pentest.

QUE PUEDE FALLAR

- Si no estan implementadas:** el hallazgo critico sigue abierto y no deberia darse por cerrado al liberar.
- Si se implementan mal:** una CSP con allowlist incompleta **bloquea el script de checkout de NetPay y el ciudadano no puede pagar**. El propio criterio de aceptacion lo advierte. Los mapas Mapbox tambien.
- HSTS de un año es practicamente irreversible:** el estado vive en el navegador de cada usuario y quitar la cabecera del servidor no lo deshace. Con `includeSubDomains`, un subdominio sin certificado valido queda inaccesible y **el rollback no lo arregla**.

QUIEN VALIDA

Ejecuto	Arlethe Mora (solo Referrer-Policy consta)
Infraestructura	Definir donde se emiten las cabeceras: en nginx o en Django. Si van en nginx, es trabajo de infra y no de la subarea. Definir el <code>max-age</code> de HSTS y si se activa <code>includeSubDomains</code> : es una decision con efecto de un año
QA	Checkout NetPay y mapas con la CSP activa, en escritorio y movil
Aprueba	Dulce Gonzalez

Mitigacion sugerida. Desplegar la CSP como `Content-Security-Policy-Report-Only` para medir violaciones con trafico real antes de bloquear. HSTS escalonado: 300 s, luego 86400 s, y solo despues un año.

3 · Endpoints sin autenticacion: se resolvio distinto a lo planteado

projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037475078

QUE SE HIZO (SEGUN COMENTARIOS)

Dulce planteo el 21-jul: *"aunque sabemos que deben ser publicos debe existir algun mecanismo para no exponerlos"*. Arlethe implemento el 27-jul **rate limiting en 21 endpoints publicos** con DRF Throttling por IP, en tres niveles:

Nivel	Limite	Endpoints
ALTO	10 req/min	3 de escritura sin autenticacion: adeudos, webhook_netpay , lecturas_arcos
MEDIO	60 req/min	5 de lectura con datos del ciudadano: vehiculos, predios, empresas, cargos, infraccion
BAJO	200 req/min	13 catalogos

Riesgo concreto para infraestructura: **webhook_netpay** quedo limitado a 10 peticiones por minuto por IP. Ese endpoint lo llama la pasarela de pagos, no un ciudadano. Si NetPay notifica desde un rango acotado de IPs y hay un pico de transacciones, **las notificaciones de pago legítimas empiezan a ser rechazadas**: el ciudadano paga y el pago no se concilia. Hay que confirmar el volumen real de callbacks de NetPay antes de liberar, o excluir ese endpoint del throttling y protegerlo por firma.

QUE FALTA O NO CONSTA

- El criterio de aceptacion dice que los endpoints sensibles **requieren autenticacion**. Se implemento rate limiting, que es una mitigacion distinta. **El criterio no se cumple como esta escrito**: o se actualiza el criterio dejando constancia de la decision, o se acepta el riesgo formalmente.
- No consta que se haya atendido la parte de **ocultar el mapa de endpoints en el bundle**.

QUIEN VALIDA

Ejecuto	Arlethe Mora · PR nay_opensir/pull/101
Infraestructura	Validar el throttling del webhook de NetPay contra el volumen real de la pasarela. Confirmar si el rate limiting por IP funciona detras del balanceador o si todas las peticiones llegan con la IP del proxy
Aprueba	Dulce Gonzalez, con decision explicita sobre el cambio de criterio

Nota tecnica para infra: si el throttling identifica por IP del cliente y el trafico entra por el balanceador, hay que verificar que se lee la IP real y no la del proxy. Si lee la del proxy, **todos los usuarios comparten el mismo cupo** y el limite se agota con trafico normal.

4 · SonarQube opensir: mas avanzado de lo que parecia

projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037486061

QUE SE HIZO (SEGUN COMENTARIOS)

Arlenthe, 27-jul: "Se corrigieron los hallazgos encontrados, solo quedo sin realizarse uno (P024 Duplicate strings) que es afectar todas las migraciones historicas porque esos son archivos que ya se ejecutaron y modificarlos es innecesario y riesgoso". PR [nay_opensir/pull/101](#).

Decision correcta y ya tomada. P024 es la regla mas voluminosa del repositorio (1059 ocurrencias, 361 h estimadas por Sonar) y apuntaba a `opensir/catalogos/migrations/`. Excluirla evita romper el historial de migraciones de Django. Esto tambien explica la diferencia entre las 8 horas asignadas y las ~777 h que estimaba Sonar: el grueso se excluyo a proposito.

QUE SIGUE SIENDO RIESGO

- **P031 `python:S4830` (13 ocurrencias) — validacion de certificado TLS.** Al activarla, **toda integracion con certificado autofirmado o cadena incompleta empieza a fallar.** Esta en `generar_pdf_ejecuciones_masivo.py` y `tasks/scripts.py`: son tareas asincronas, fallan en silencio. **Infra debe confirmar que los servicios que consumen esos procesos tienen certificados validos.**
- **P026 `python:S5754` (162) — acotar `except` genericos.** Excepciones que antes se tragaban ahora propagan: errores 500 nuevos en catastro.
- **P036 `python:S2068` (5) — credenciales hardcodeadas.** Si se movieron a variables de entorno, **deben quedar configuradas en el entorno productivo** o falla la integracion de infracciones.

5 · SonarQube retys y rotacion de tokens Mapbox

projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037486064

QUE SE HIZO

- Hallazgos P060, P061 y P062 resueltos, y despues "se solucionaron los hallazgos restantes". PRs [tramites/pull/89](#) y [nay_retys/pull/1](#). Conflictos con la rama `dev-vps` resueltos el 31-jul.
- En paralelo se rotaron los tokens Mapbox con restriccion por dominio en SIR, Ventanilla unica y retys: PRs [nay_OPENSIR-FRONTEND/pull/52](#), [nay_ventanilla-unica/pull/29](#) y [nay_retys/pull/2](#).

Punto a confirmar. El hallazgo P067 reporta un `accessToken` de Mapbox hardcodeado en `src/components/MultipleMap.jsx`. La rotacion de tokens incluye un PR sobre `nay_retys`, por lo que probablemente ya quedo cubierto, pero **no consta explicitamente que ese token hardcodeado sea el que se reemplazo**. Si se rota el token sin actualizar ese archivo, los mapas de retys dejan de cargar. Vale una verificacion rapida antes de liberar.

6 · Datos de pago en localStorage y SRI de NetPay

projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037475075

QUE SE HIZO

- Cambios en PR `nay_ventanilla-unica/pull/30`, construido sobre la rama del PR `pull/26` porque la implementacion de NetPay cambio mucho. **Dependencia de orden: primero se integra el 26, despues el 30.** Mario Merel confirmo el 8-sep que ya esta en QA.
- En la tarea de SRI se autohospedo el SDK de NetPay y se agrego el script `fetch:netpay-sdk` al `package.json` para regenerar los valores de integridad al actualizar el SDK. PRs `pull/33` y `pull/26`.

Incidente relevante para infraestructura, 25 de agosto. Durante la validacion del pago en linea Jair Guerrero reporto un error. Alejandro Leon diagnostico:

"parece ser que la config de nginx es la que esta haciendo que el iframe donde esta alojado la pasarela de pagos de netpay true"

Ya hay un precedente de que la configuracion de nginx rompe el cobro en linea. Esto refuerza las peticiones 1 y 2: cualquier cambio de cabeceras o de redireccion HTTPS toca el mismo camino que el iframe de la pasarela.

QUE FALTA

- El 8-sep aparecieron conflictos en DEV que Alejandro German esta resolviendo, ligados al PR 26.
- Autohospedar el SDK obliga a un proceso manual de actualizacion. **Hay que definir quien vigila las actualizaciones de seguridad del SDK de NetPay**, o el sistema se queda con una version vieja indefinidamente.

Lo que esta sin iniciar y necesita su valoracion

Riesgo	Subtarea y estado	Que dicen los comentarios	Que necesitamos valorar
CRITICO	Llaves privadas NetPay en el bundle No iniciada · cero comentarios task-detail/106599000037486067	Ninguno. Es la unica subtarea del hito sin un solo comentario desde que se creo	Las llaves <code>sk_netpay_*</code> estan expuestas en texto claro y permiten reembolsos. Hay que rotarlas en produccion, no solo moverlas al backend. Definir quien ejecuta la rotacion y coordinarla con NetPay para no cortar el cobro
IMPORTANTE	Restringir CORS No iniciada task-detail/106599000037486071	Dulce, 21-jul: "@miguel angel ramos luna esta es tuya". Sin actividad desde entonces	Ya esta asignada a infraestructura y lleva mes y medio sin arrancar. Hay que sustituir <code>Access-Control-Allow-Origin: *</code> por lista blanca en hacienda, apifuncionarios y reporteador, e inventariar antes que consumidores existen para no romper integraciones
IMPORTANTE	Reporteador ASP.NET publico Cancelada task-detail/106599000037479061	Arlenthe, 27-jul: "esta tarea me parece que es mas de infraestructura que de codigo, quizas restricciones desde el firewall"	Se cancelo porque es tema de infraestructura, no porque el riesgo se haya resuelto. La app de reporteria interna sigue accesible desde Internet. Valorar restriccion por IP, VPN o red interna, y reabrir la subtarea o documentar el riesgo aceptado
CRITICO (rendimiento)	Rendimiento del portal publico No iniciada task-detail/106599000037486076	Alejandro Leon, 10-ago: no puede arrancar hasta cerrar NABO-T161, NABO-T153 y NABO-T104, porque los cambios de NetPay son grandes y habria conflictos	7220 ms de recursos que bloquean el render en movil y 4383 KiB de imagenes sin optimizar. Buena parte se resuelve desde infraestructura sin tocar codigo: compresion, cache, HTTP/2, CDN y conversion de imagenes. Valorar que se puede adelantar por esa via mientras el frontend sigue bloqueado

Dos de las cuatro sin iniciar son de infraestructura. CORS ya esta asignada a Miguel Angel Ramos y el reporteador se cancelo justamente porque corresponde a infra. No estan detenidas por falta de desarrollo, sino esperando una definicion de su lado.

Orden de despliegue sugerido

1. **Datos de pago en localStorage y retys.** Menor radio de impacto, sirven para validar el proceso.
2. **HTTPS** en ventana de mantenimiento, con rollback preparado, y **solo despues de que infra confirme el comportamiento del balanceador Huawei.**
3. **Cabeceras** con CSP en Report-Only y HSTS escalonado, una vez definido si van en nginx o en Django.
4. **Endpoints y throttling,** despues de validar el limite del webhook de NetPay.
5. **SonarQube opensir,** con el diff revisado y los certificados de las integraciones confirmados.

HTTPS y cabeceras no deben salir el mismo dia. Si algo falla no se podra distinguir si fue la redireccion o la CSP, y con HSTS ya emitido el rollback no devuelve al estado anterior.

Enlaces

Elemento	Enlace
Hito completo en Zoho	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037479054
Forzar HTTPS	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037475081
Cabeceras de seguridad	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037480070
Endpoints sin autenticacion	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037475078
SonarQube opensir	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037486061
SonarQube retys	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037486064
Datos de pago en localStorage	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037475075
Llaves NetPay (sin iniciar)	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037486067
CORS (sin iniciar)	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037486071
Reporteador ASP.NET (cancelada)	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037479061
Rendimiento portal publico	https://projects.zoho.com/portal/sigobproyectos#zp/task-detail/106599000037486076
PR principal de backend	https://github.com/sigob-open-source/nay_opensir/pull/101
PR de ajuste https y nginx	https://github.com/sigob-open-source/nay_opensir/pull/116

Alcance y limitaciones

Este documento se construyo leyendo descripciones, estados, dueños, revisores y **los 64 comentarios** de las 14 subtareas registradas en Zoho. **No se reviso el codigo fuente, los PRs ni la configuracion real de los servidores.**

Cuando se indica que algo "no consta", significa que no aparece en los comentarios de Zoho: puede estar hecho y sin registrar. Por eso varias peticiones son de confirmacion y no de ejecucion.

Generado a partir del estado registrado en Zoho Projects el 2026-09-08. Los nombres provienen de los campos dueño, revisor y revisor de desarrollo, y de los comentarios de cada subtarea. Es un insumo para la decision, no la sustituye: la validacion tecnica y la aprobacion de salida corresponden al Tech Lead, al area de infraestructura y al PO.